

Tool: Auth & Authorization Checklist

Apa: daftar periksa autentikasi (authn — siapa kamu) + otorisasi (authz — boleh apa kamu) per endpoint sensitif. **Kapan dipake:** tiap endpoint butuh proteksi (SOP-SA-03). **Framework:** OWASP ASVS, OWASP Top 10 (Broken Auth + Broken Access Control), ISO/IEC 27001 (Annex A access control). **Aturan:** semua  + **test akses negatif pass** → endpoint aman. **Default deny, allow eksplisit. Never roll-your-own crypto.**

Authentication (siapa kamu)

- [] **Library proven** — Lucia / Better Auth / Passport (BUKAN crypto buatan sendiri)
- [] **Token/session divalidasi di boundary** (middleware) sebelum business logic
- [] **Rate limit** di login/signup/reset (anti brute-force)
- [] **Secret di env** (12-Factor) — never di kode
- [] **Token expiry + refresh** (kalau JWT) — gak token abadi
- [] **Password** — hashed (bcrypt/argon2), never plaintext

Authorization (boleh apa kamu)

- [] **Default deny** — akses ditolak kecuali di-allow eksplisit
- [] **Role/scope check** di tiap endpoint sensitif
- [] **Ownership check** — user A gak bisa akses data user B (cek owner, bukan cuma role)
- [] **Money/saldo isolasi STRICT** (Tata mandate) — aksi finansial authz ketat + audit
- [] **Privilege escalation** — gak ada cara user naikin role sendiri lewat input

Verification (test negatif — wajib)

- [] Tanpa token → 401 UNAUTHENTICATED
- [] Token valid, role salah → 403 FORBIDDEN
- [] Token valid, akses data orang lain → 403 (ownership)
- [] Token expired → 401

Hygiene

- [] **Error gak leak** — "login dulu" bukan "user X password salah" (anti user enumeration)
 - [] **Log auth event** — login sukses/gagal di-audit (siapa, kapan, IP)
 - [] **No secret di log** — token/password di-redact
-

CONTOH TERISI

Auth check: `GET /api/orders/{id}` (Proyek-Contoh — detail order, lihat pembayaran masuk)

Authn:

- ✓ Better Auth, session httpOnly cookie (web app)
- ✓ Session divalidasi di middleware sebelum handler
- ✓ Rate limit login 5/min; secret di .env; password argon2

Authz:

- ✓ Default deny – detail order butuh login
- ✓ Ownership check: `req.user.id === order.owner_id`, else 403 NOT_ORDER_OWNER
- ✓ Money isolasi: payment detail (nominal) HANYA owner – user lain gak bisa lihat total
- ✓ Gak ada field `role` di body yang bisa user-set (anti privilege escalation)

Verifikasi (test negatif):

- ✓ Tanpa login → 401 UNAUTHENTICATED
- ✓ Login tapi bukan owner → 403 NOT_ORDER_OWNER (← INI yang krusial: data money orang lain)
- ✓ Session expired → 401

Hygiene:

- ✓ Login gagal → "email/password salah" generik (gak bocor mana yang salah)
 - ✓ Log: `auth.login.success` / `auth.login.failed` (user-id, IP, ts) – redact password
- Lolos. Money/saldo isolasi STRICT terpenuhi (Tata mandate). Evidence test di log.md.

Yang paling sering bolong: **ownership check**. Role "user" doang gak cukup — harus cek user ini **pemilik resource ini**. Tanpa itu, user A bisa lihat payment order user B walau dua-duanya role "user". Itu Broken Access Control (OWASP) + langgar money isolasi Tata.